

Air University



SSDD (Lab)

Year 2026

Mr. Anjum Rehman

Academic Year: 2024 – 2028
Department of Cyber Security

USAMA ARSHAD | 247141
BS – Cyber Security – Fall – 24 (A)
Date of Submission: March 17, 2026

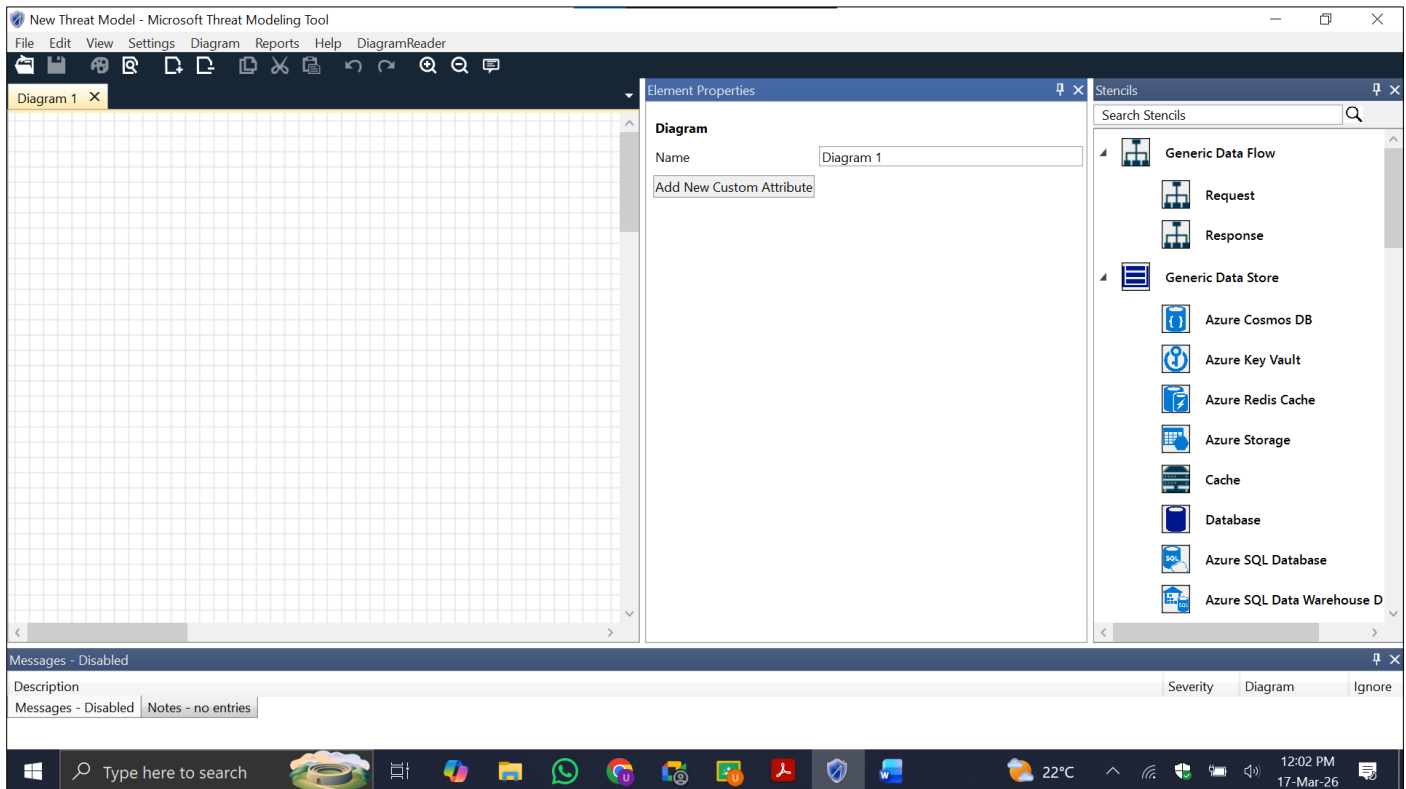
Lab # 07

Task 1: Introduction & Installation

Instructions: Download and install the Microsoft Threat Modeling Tool

Explore: Stencils (process, data store, external entity) Properties window Threats pane

Installed the tool from the official site of Microsoft:



Microsoft Threat Modeling Tool was installed and key features including stencils, properties window and threats pane were explored.

Task 2: Create a Basic Data Flow Diagram (DFD)

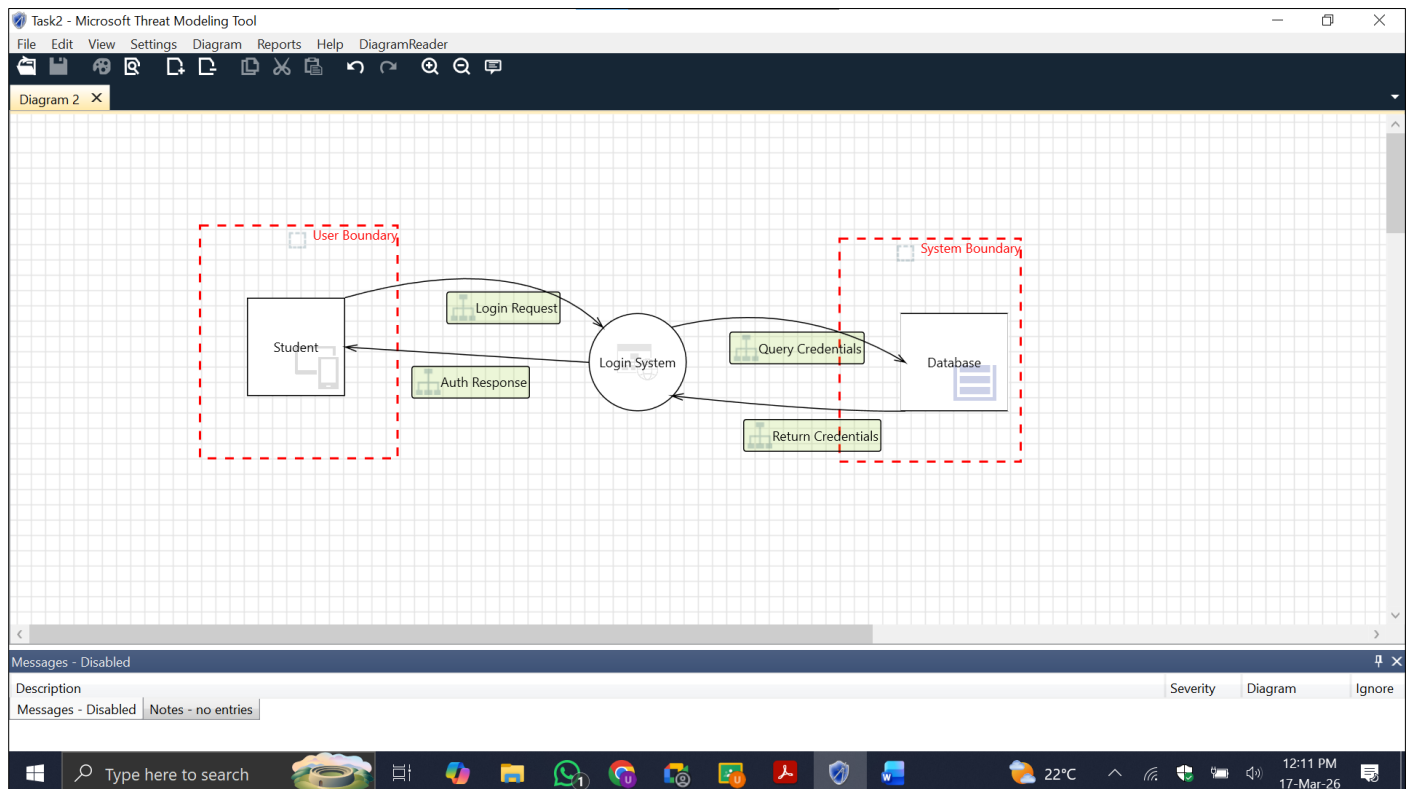
Scenario: Simple Student Login System Add:

External Entity → Student

Process → Login System

Data Store → Database

Connect using data flows



A basic DFD was created for the Student Login System.

Task 3: Identify Threats using STRIDE

Use the built-in threat generation feature. Analyze threats under:

Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege

Threat List:

ID	Diagram	Changed By	Last Modified	State	Title	STRIDE Categ	Description	Justification	Interaction	Possible Mitig	Severity	SDL Phase
0	Diagram 2	ELITEBOOK\HP	17-Mar-26 12:21	Not Started	An adversary ma	Elevation of Privi	An adversary ma	Exploiting login v	Login Request	Implement impli	High	Design
1	Diagram 2	ELITEBOOK\HP	17-Mar-26 12:20	Not Started	An adversary car	Information Disc	An adversary car	Login credentials	Login Request	Do not expose s	High	Implementation
2	Diagram 2		Generated	Not Started	An adversary m	Information Dis	An adversary m		Login Request	Ensure that the	High	Implementation
3	Diagram 2		Generated	Not Started	An adversary c	Information Dis	An adversary c		Login Request	Implement Cert	High	Implementation
4	Diagram 2		Generated	Not Started	An adversary c	Information Dis	If application s		Login Request	Encrypt sensitiv	High	Implementation
5	Diagram 2		Generated	Not Started	An adversary c	Information Dis	An adversary c		Login Request	Do not expose :	High	Implementation
6	Diagram 2	ELITEBOOK\HP	17-Mar-26 12:20	Not Started	Attacker can den	Repudiation	Proper logging c	Without audit lo	Login Request	Ensure that audit	Medium	Implementation
7	Diagram 2	ELITEBOOK\HP	17-Mar-26 12:17	Not Started	An adversary car	Spoofing	Ensure that TLS c	An adversary cou	Login Request	Verify X.509 certi	High	Implementation
8	Diagram 2		Generated	Not Started	An adversary c	Spoofing	Attackers can e		Login Request	Explicitly disabl	High	Implementation
9	Diagram 2		Generated	Not Started	An adversary c	Spoofing	Phishing is atte		Login Request	Verify X.509 cer	High	Implementation
10	Diagram 2		Generated	Not Started	An adversary m	Spoofing	If proper authen		Login Request	Consider using	High	Design
11	Diagram 2	ELITEBOOK\HP	17-Mar-26 12:20	Not Started	An adversary car	Tampering	An adversary car	Login data in tra	Login Request	Obfuscate gener	High	Design

STRIDE threat generation was applied to the Student Login System. Full analysis is provided in Task 6.

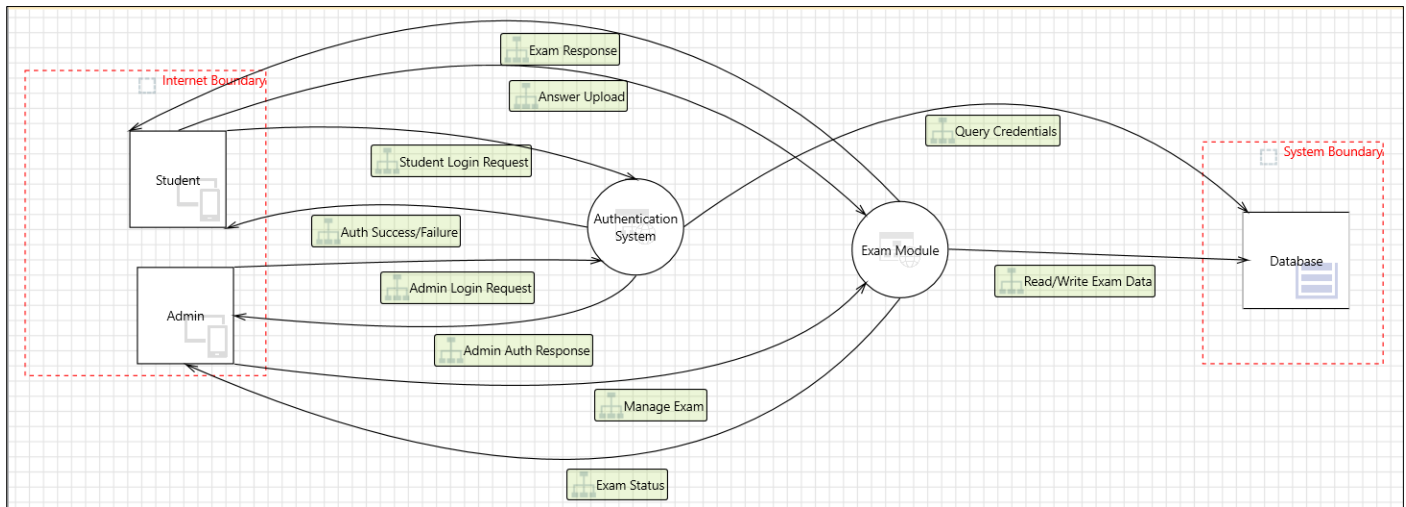
Task 4: Apply to Real Scenario

Scenario: Online Exam Management System:

Student login, Answer upload, Admin dashboard

Create a full DFD Add:

External entities (Student, Admin), Processes (Authentication, Exam Module), Data stores (Database)



full DFD was created for the Online Exam Management System

Threat List:

Only related to stride are justified else needs investigation.

35	Diagram 2	ELITEBOOK/HP	17-Mar-26 1:08:22	Needs Investig	An adversary ma	Elevation of Privi	An adversary ma	An adversary coi	Student Login Re	Implement impli	High	Design
36	Diagram 2	ELITEBOOK/HP	17-Mar-26 1:08:22	Needs Investig	An adversary car	Information Disc	An adversary car	An adversary coi	Student Login Re	Do not expose s	High	Implementation
37	Diagram 2		Generated	Not Started	An adversary m	Information Dis	An adversary m		Student Login F	Ensure that the	High	Implementatio
38	Diagram 2		Generated	Not Started	An adversary c	Information Dis	An adversary c		Student Login F	Implement Cert	High	Implementatio
39	Diagram 2		Generated	Not Started	An adversary c	Information Dis	If application s		Student Login F	Encrypt sensitiv	High	Implementatio
40	Diagram 2		Generated	Not Started	An adversary c	Information Dis	An adversary c		Student Login F	Do not expose :	High	Implementatio
41	Diagram 2	ELITEBOOK/HP	17-Mar-26 1:07:44	Needs Investig	Attacker can den	Repudiation	Proper logging c	Without proper i	Student Login Re	Ensure that audit	Medium	Implementation
42	Diagram 2	ELITEBOOK/HP	17-Mar-26 1:07:44	Needs Investig	An adversary car	Spoofing	Ensure that TLS c	An adversary co	Student Login Re	Verify X.509 certi	High	Implementation
43	Diagram 2		Generated	Not Started	An adversary c	Spoofing	Attackers can e		Student Login F	Explicitly disabl	High	Implementatio
44	Diagram 2		Generated	Not Started	An adversary c	Spoofing	Phishing is atte		Student Login F	Verify X.509 cer	High	Implementatio
45	Diagram 2		Generated	Not Started	An adversary m	Spoofing	If proper authen		Student Login F	Consider using .	High	Design
46	Diagram 2	ELITEBOOK/HP	17-Mar-26 1:07:44	Needs Investig	An adversary car	Tampering	An adversary car	An adversary co	Student Login Re	Obfuscate gener	High	Design

Task 5: Suggest Security Controls

Security controls were identified based on generated threats. Full recommendations are documented in Task 6.

Task 6: Report Writing

1. Introduction to Threat Modeling

Threat modeling is a systematic approach aimed at identifying, analyzing, and mitigating potential security threats within a software system during its design phase. This proactive method allows developers to uncover vulnerabilities before they can be exploited in a production environment. By mapping how data flows through the system and pinpointing trust boundaries, threat modeling empowers teams to prioritize security risks and implement the necessary controls early on in the Software Development Life Cycle (SDLC).

One of the most prominent methodologies for threat modeling is the STRIDE framework, created by Microsoft. STRIDE breaks down threats into six categories—Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege—offering a thorough checklist that helps identify security weaknesses across every component of a system.

2. Tool Overview

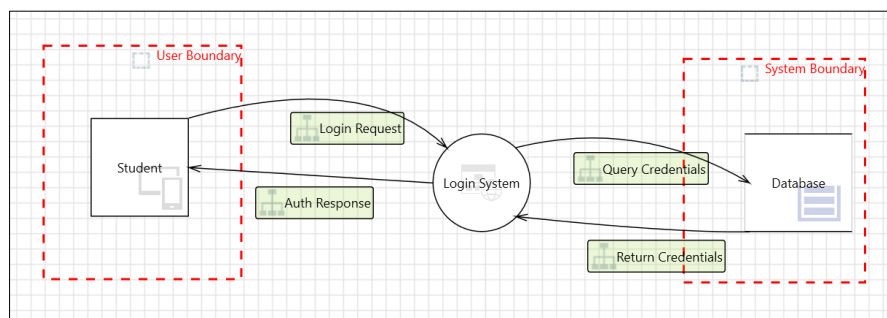
Microsoft Threat Modeling Tool is a free, developer-focused security tool that supports the creation of Data Flow Diagrams (DFDs) and automatically generates STRIDE-based threats based on the diagram elements and their interactions.

Key features include:

Feature	Description
Stencils	Pre-built shapes for External Entities, Processes, Data Stores and Trust Boundaries
Properties Window	Displays and allows editing of element attributes and threat details
Threat Generation	Automatically generates STRIDE threats based on DFD interactions
Threat Pane	Lists all generated threats with category, description, priority and state
Report Export	Exports full threat modeling report as HTML

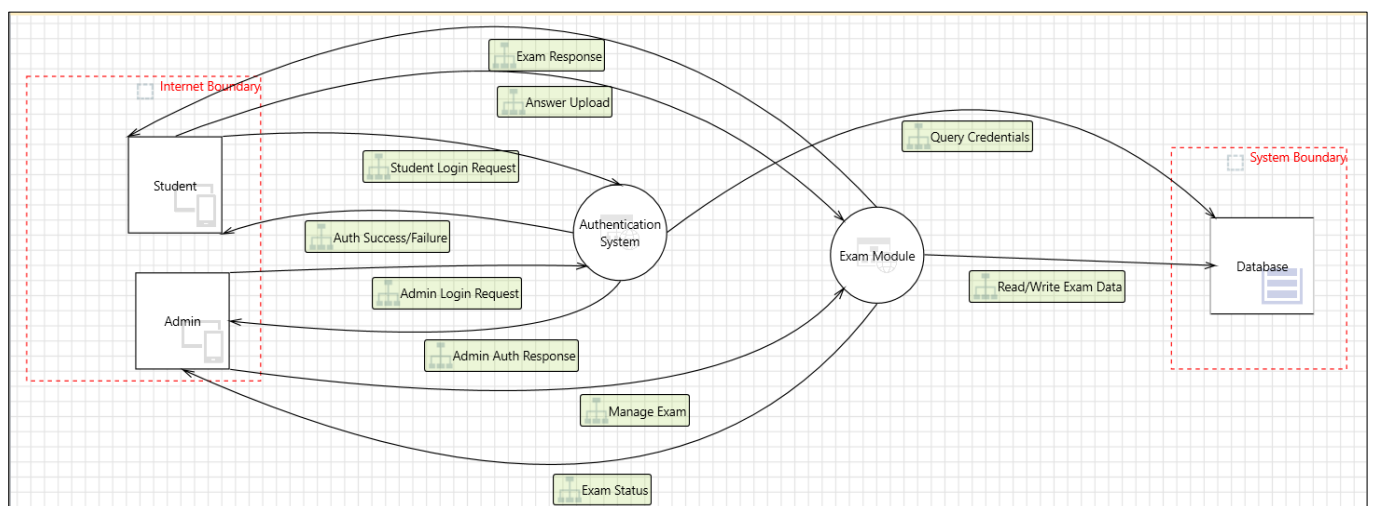
3. DFD Diagrams

Task 2 — Student Login System



The Student Login System DFD models the basic authentication flow between a Student external entity, a Login System process, and a Database data store. The Internet trust boundary separates the student from the internal system components.

Task 4 — Online Exam Management System



The Online Exam Management System DFD models a more complex scenario involving two external entities (Student and Admin), two processes (Authentication System and Exam Module), and a central Database. Two

trust boundaries are used — Internet Boundary separating external users and System Boundary protecting the database.

4. Threat Analysis

Task 3 — Student Login System STRIDE Analysis

STRIDE Category	Threat ID	Description	Justification
Spoofing	7	Adversary spoofs student identity	An attacker could forge credentials to impersonate a legitimate student and gain unauthorized access
Tampering	11	Adversary tampers with login request	Login data in transit could be modified to bypass authentication if TLS is not enforced
Repudiation	6	Attacker denies login attempts	Without audit logging, unauthorized login attempts cannot be traced or attributed
Information Disclosure	1	Adversary intercepts credentials	Login credentials could be exposed if the communication channel is unencrypted
Denial of Service	N/A	Login system overwhelmed	Excessive requests could flood the login system causing downtime for legitimate students
Elevation of Privilege	0	Adversary gains elevated access	Exploiting login vulnerabilities could allow a student to gain admin-level privileges

Task 4 — Online Exam Management System STRIDE Analysis

ID	Interaction	STRIDE Category	Threat Description	Justification	Priority
42	Student Login Request	Spoofing	Adversary spoofs student identity	An adversary could forge student login credentials to impersonate a legitimate student and gain unauthorized access to the exam system	High
46	Student Login Request	Tampering	Adversary tampers with login data	Login request data could be modified in transit to bypass authentication if TLS encryption is not enforced on the communication channel	High
41	Student Login Request	Repudiation	Attacker denies login attempts	Without proper audit logging, a student could deny having accessed the system or submitted answers leaving no traceable evidence	Medium
36	Student Login Request	Information Disclosure	Credentials intercepted	Sensitive student login credentials could be intercepted if the data flow to the Authentication System is not encrypted with TLS/HTTPS	High

35	Student Login Request	Denial of Service	Login system flooded	Excessive login requests could overwhelm the Authentication System exhausting server resources and blocking legitimate students from accessing exams	High
35	Student Login Request	Elevation of Privilege	Student gains admin access	Vulnerabilities in the Authentication System could be exploited to escalate a student account to admin level gaining unauthorized exam management access	High

5. Security Recommendations

STRIDE Category	Threat	Security Control	Implementation
Spoofing	Student/Admin identity spoofed	Multi-Factor Authentication (MFA)	Require OTP or email verification in addition to password for both student and admin login
Tampering	Login data modified in transit	TLS/HTTPS Encryption	Enforce TLS 1.3 on all data flows between clients and server to prevent man-in-the-middle attacks
Repudiation	Login attempts denied	Audit Logging	Log all authentication attempts, answer uploads and admin actions with timestamps and user IDs
Information Disclosure	Credentials intercepted	Data Encryption	Encrypt all sensitive data in transit using TLS and at rest in the database using AES-256
Denial of Service	System flooded with requests	Rate Limiting & CAPTCHA	Implement rate limiting on login and answer upload endpoints and add CAPTCHA to prevent automated attacks
Elevation of Privilege	Student gains admin access	Role-Based Access Control (RBAC)	Enforce strict RBAC so students can only access exam functions and admins can only access management functions

In addition to the specific controls outlined in STRIDE, the Online Exam Management System should include robust input validation for all data submitted by users to protect against injection attacks. It's also crucial to implement session timeout mechanisms that automatically log out users after a period of inactivity. Furthermore, conducting regular security audits is essential to discover and address any vulnerabilities before they can be exploited.